

BRIEFINGS

black hat

Forgotten but Not Gone: Unauthenticated RCEs and LPEs in Legacy Linux Services

Ron Ben Yizhak, SafeBreach

ABOUT ME

Security Research Team Lead
@ SafeBreach

Published privilege escalation
and code injection methods for
Windows

Previous talks

- DEF CON 30-33
 - DEF CON Singapore
 - TyphoonCon 2026
-

 SafeBreach



Agenda

Common services in Linux

Research initiator (CVE-2026-24061)

Privilege Escalation in GNU TelnetD

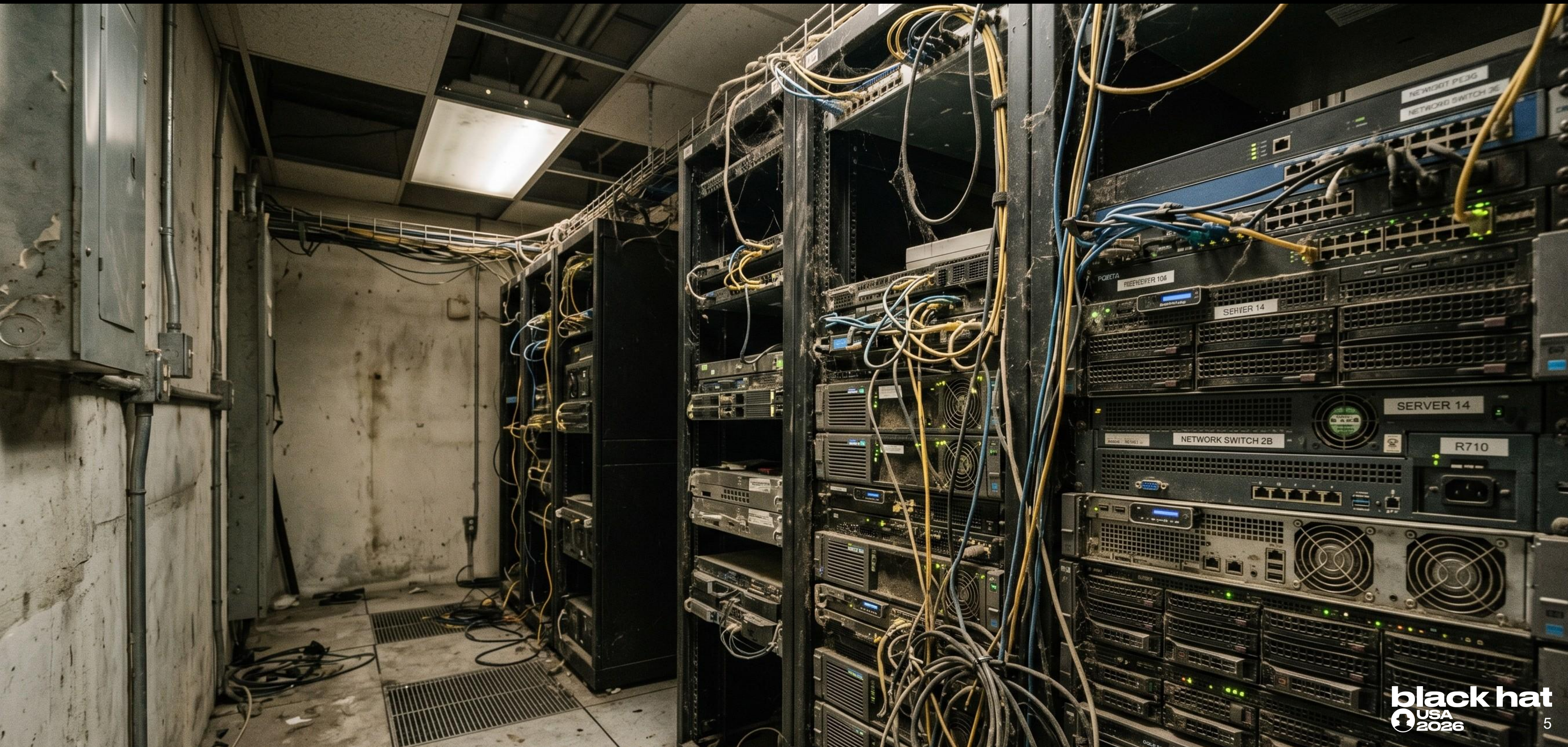
Samba Inner Workings

Unauthenticated RCE in Samba via SAMR

Unauthenticated RCE in Samba via Spoolss

Takeaways

When was the last time you checked what your network devices are running?



How long ago you updated your printer?



Telnet

Allows accessing the terminal of another machine remotely

Legacy protocol superseded by SSH

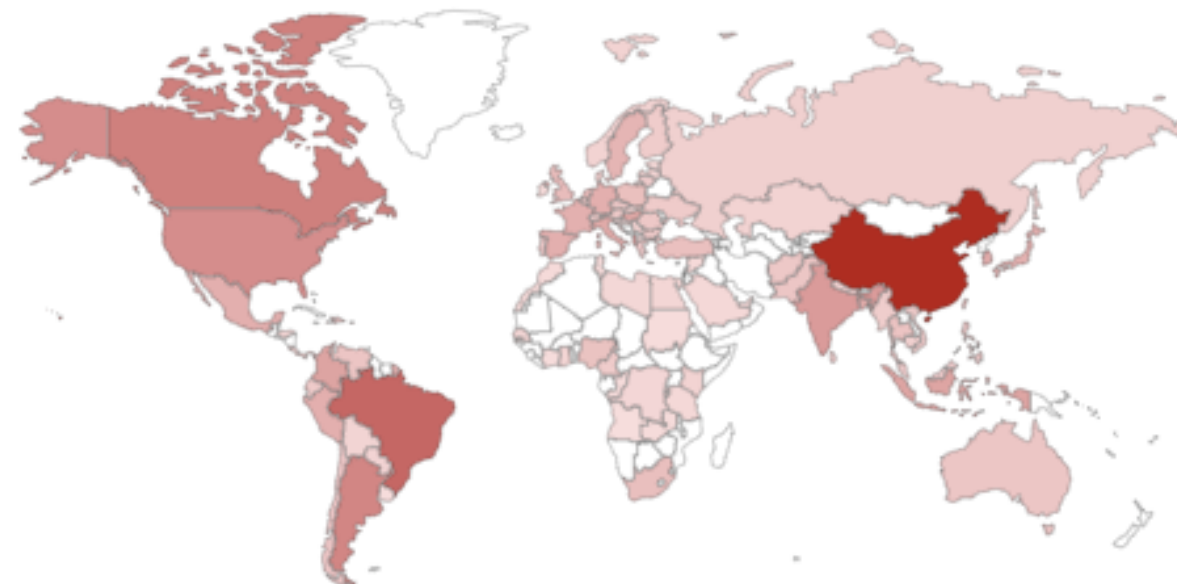
Still widely used globally

Shodan Report

telnet

Total: 270,235

// GENERAL



🌐 Countries

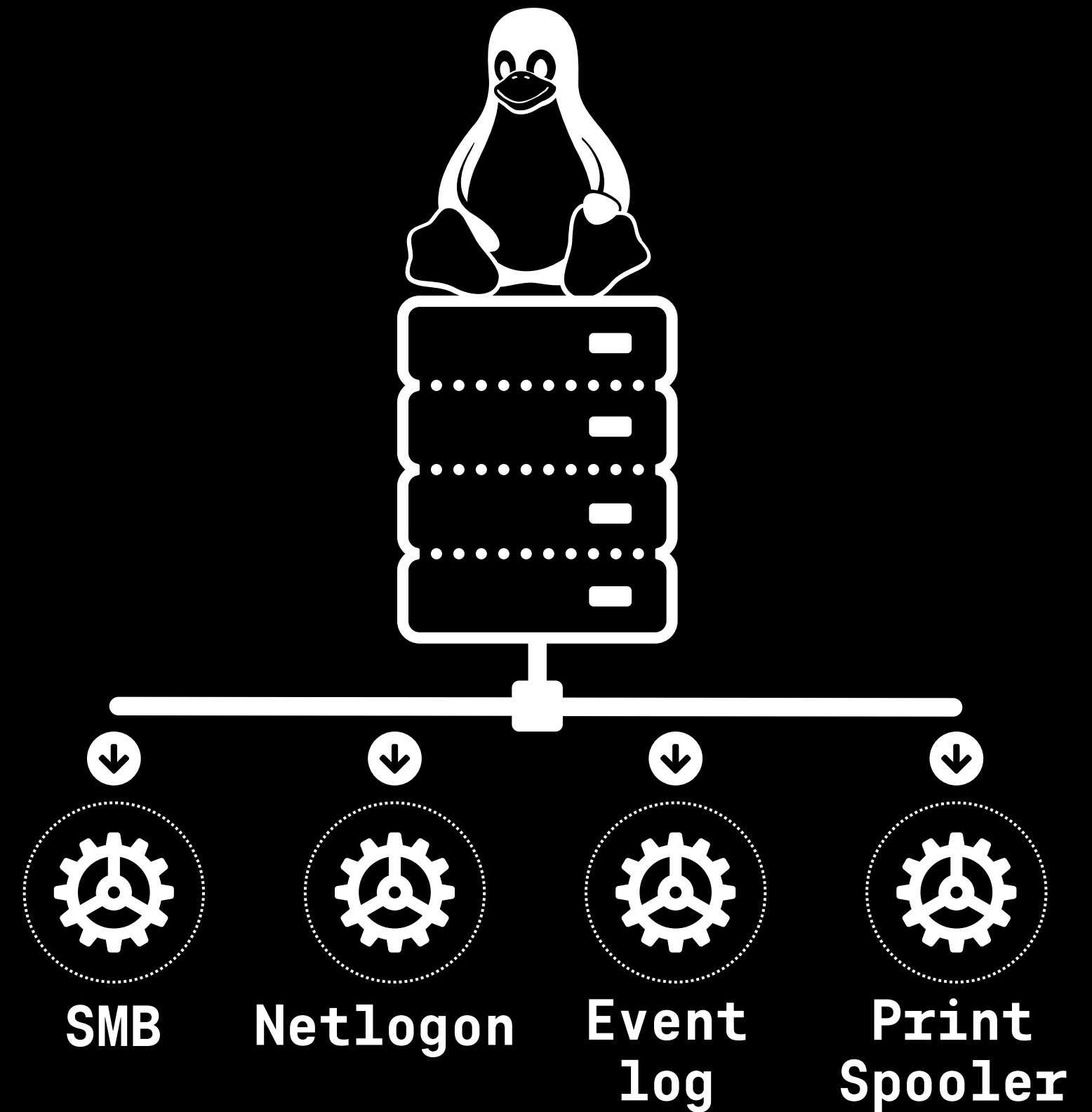
China	194,311
Brazil	25,148
Canada	9,679
Argentina	7,536
United States	5,263

Samba

Open-source implementation
of SMB and Active Directory

Exposes the RPC interface of
common services

Released in 1992



RCE in TelnetD

Reported by Carlos Cortes Alvarez
on January 19th, 2026

Issued as CVE-2026-24061

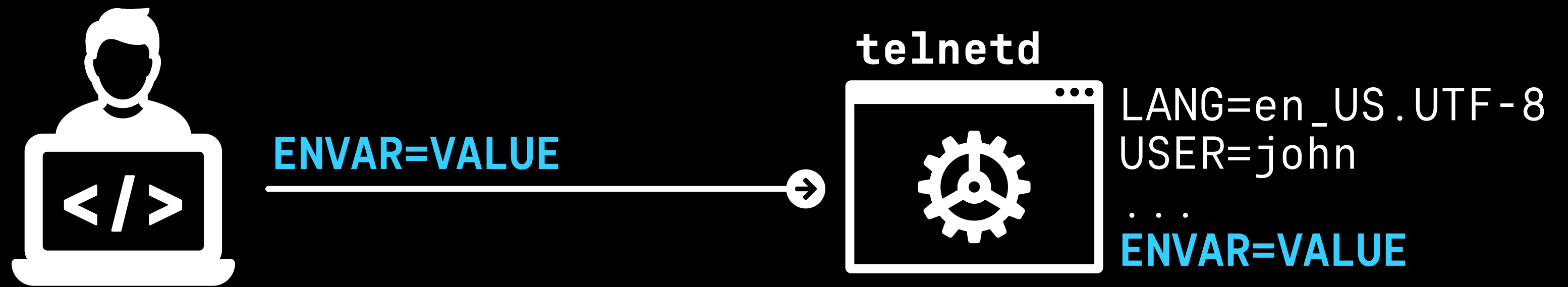
CVSS 9.8

Stayed undetected since 2015



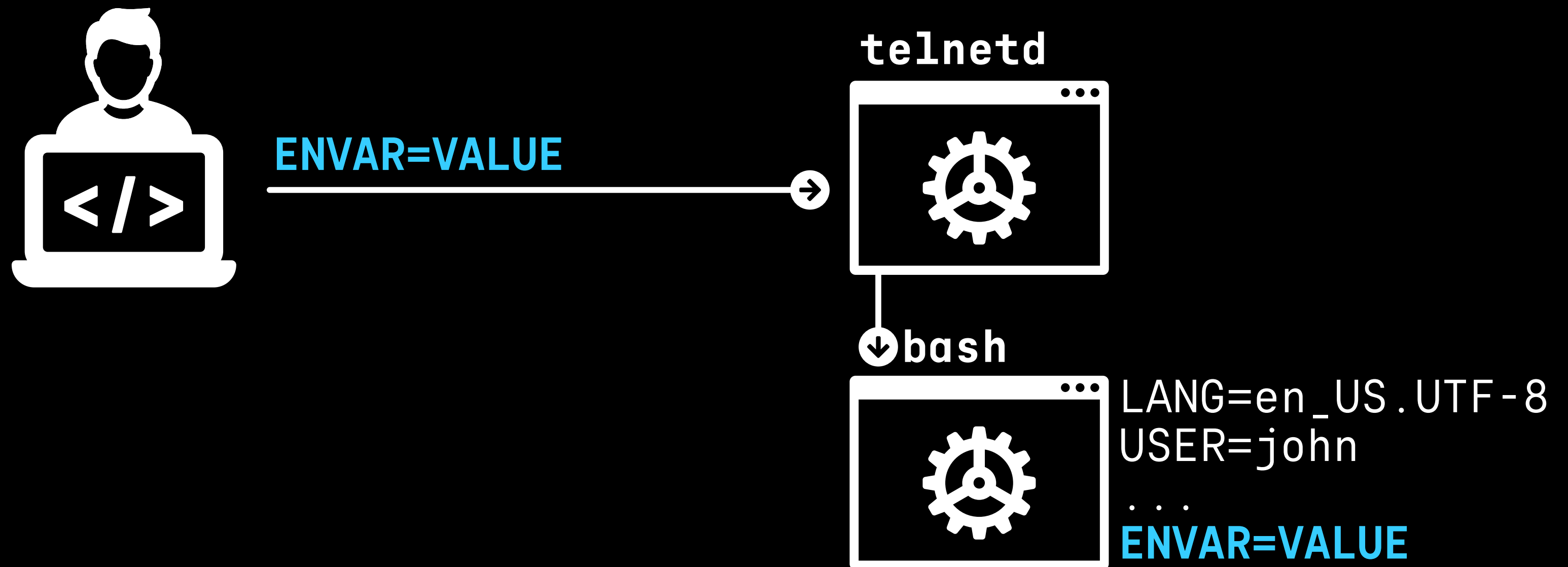
Root Cause Analysis

Telnetd allows unauthenticated clients to set its environment variables



Root Cause Analysis

The spawned shell will inherit the new environment variables



Root Cause Analysis

Telnetd doesn't perform the authentication itself



Root Cause Analysis

Telnetd executes login with a format string

In 2015 it was updated

```
- PATH_LOGIN " -p -h %h %?u{-f %u}"
```

```
+ PATH_LOGIN " -p -h %h %?u{-f %u}{%U}"
```


Root Cause Analysis

```
PATH_LOGIN " -p -h %h %?u{-f %u}{%U}"
```

```
~$ /usr/bin/login --help
```

Usage:

```
login [-p] [-h <host>] [-H] [[-f] <username>]
```

Begin a session on the system.

Options:

-p	do not destroy the environment
-f	skip a login authentication
-h <host>	hostname to be used for utmp logging
-H	suppress hostname in the login prompt
--help	display this help
-V, --version	display version

Root Cause Analysis

```
PATH_LOGIN " -p -h %h %?u{-f %u}{%U}"
```

```
~$ /usr/bin/login --help
```

Usage:

```
login [-p] [-h <host>] [-H] [[-f] <username>]
```

Begin a session on the system.

Options:

-p	do not destroy the environment
-f	skip a login authentication
-h <host>	hostname to be used for utmp logging
-H	suppress hostname in the login prompt
--help	display this help
-V, --version	display version

Root Cause Analysis

```
PATH_LOGIN " -p -h %h %?u{-f %u}{%U}"
```

%h = The remote hostname of the connecting client

Root Cause Analysis

```
PATH_LOGIN " -p -h %h %?u{-f %u}{%U}"
```

%h = The remote hostname of the connecting client

%?u = Is the variable “user_name” non-empty?

Root Cause Analysis

```
PATH_LOGIN " -p -h %h %?u{-f %u}{%U}"
```

%h = The remote hostname of the connecting client

%?u = Is the variable “user_name” non-empty?

{-f %u} = True block

Root Cause Analysis

```
PATH_LOGIN " -p -h %h %?u{-f %u}{%U}"
```

%h = The remote hostname of the connecting client

%?u = Is the variable “user_name” non-empty?

{-f %u} = True block

{%U} = False block

Root Cause Analysis

By default, “user_name” is not set

%U is mapped to \$USER

Command line can be simplified as follows

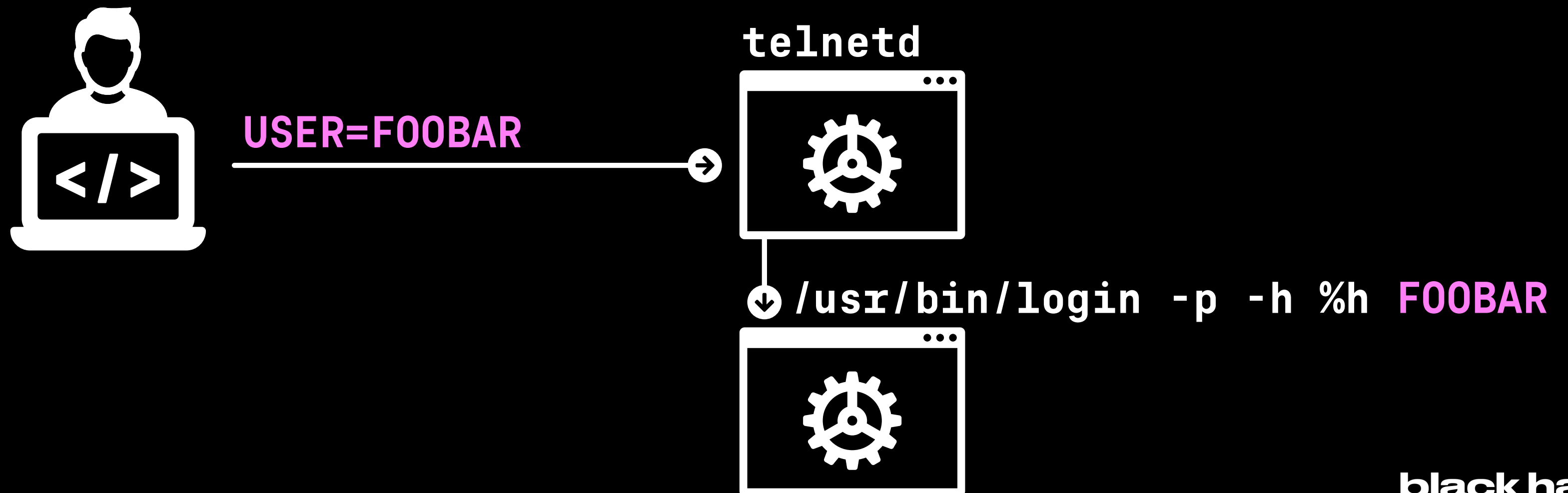
```
/usr/bin/login -p -h remote_hostname $USER
```


Root Cause Analysis

The client controls the environment variables of telnetd

\$USER is not sanitized before formatting it!

Arbitrary parameters can be injected to the command line



Root Cause Analysis

```
~$ /usr/bin/login --help
```

Usage:

```
login [-p] [-h <host>] [-H] [[-f] <username>]
```

Begin a session on the system.

Options:

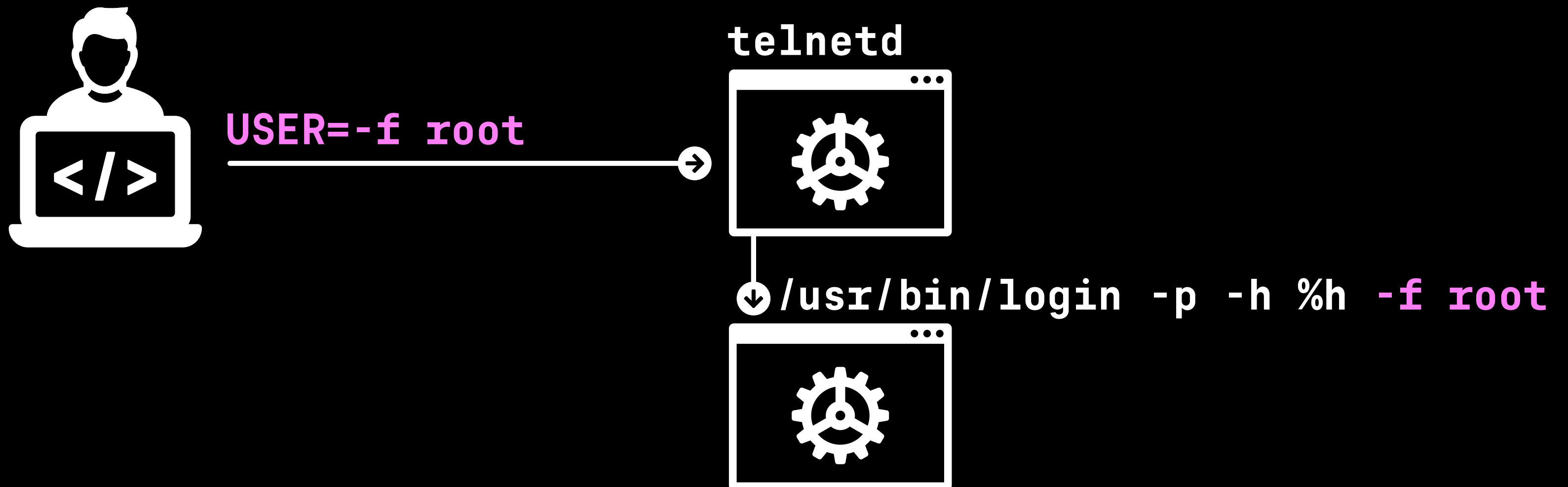
-p	do not destroy the environment
-f	skip a login authentication
-h <host>	hostname to be used for utmp logging
-H	suppress hostname in the login prompt
--help	display this help
-V, --version	display version



Root Cause Analysis

The -f parameter can be injected to skip authentication

Any username can be set



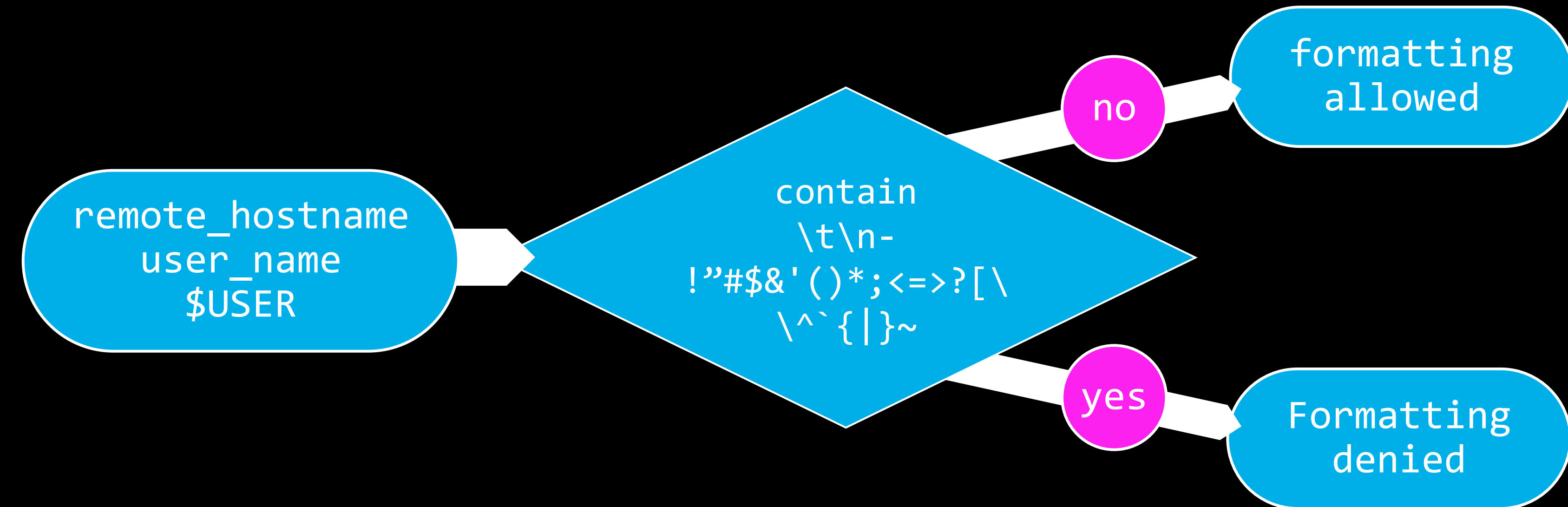
Security Patch

Parameters cannot be set before the username

```
- PATH_LOGIN " -p -h %h %?u{-f %u}{%U}"
```

```
+ PATH_LOGIN " -p -h %h %?u{-f -- %u}{-- %U}"
```

Variables are sanitized for shell metachars



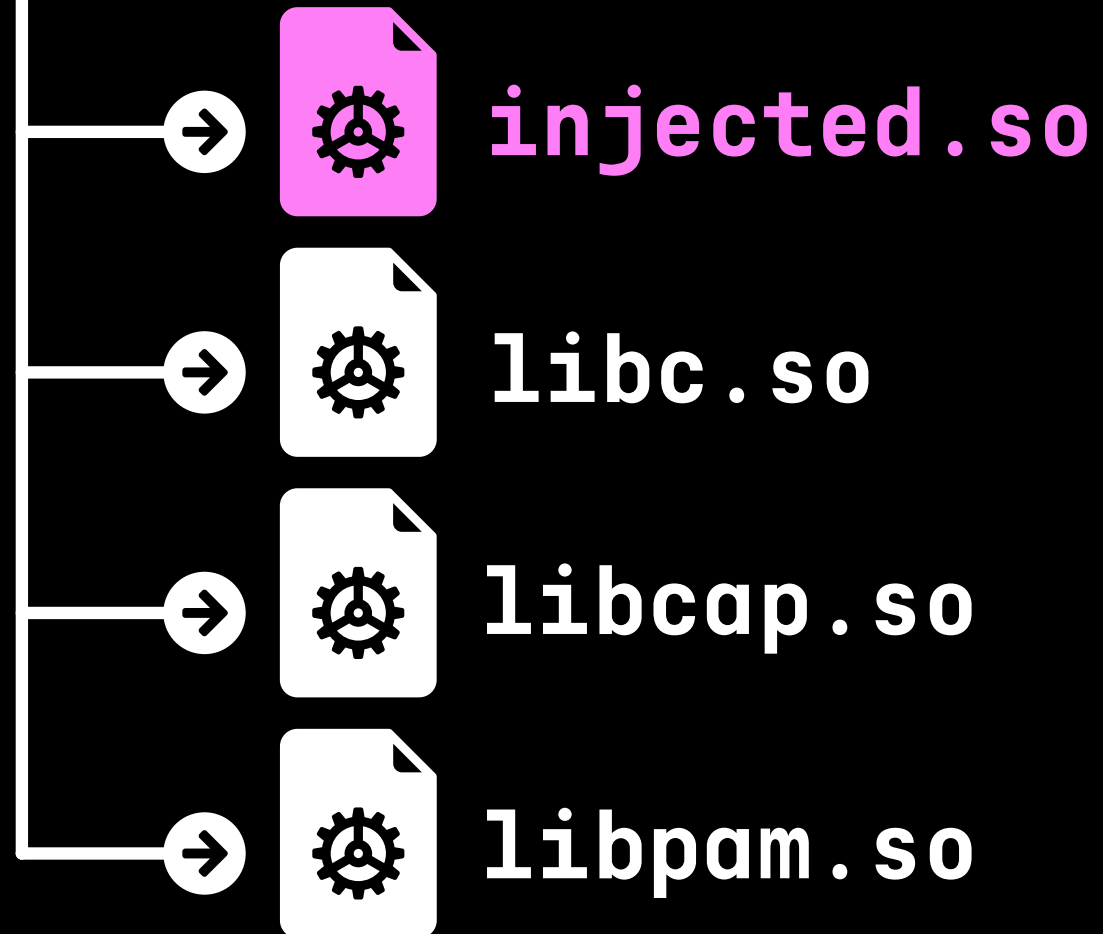
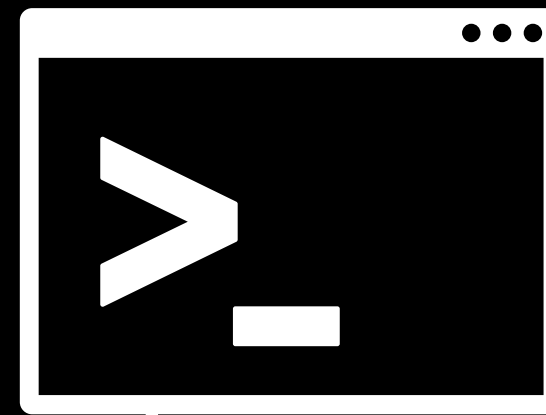
What else stayed hidden?



Manipulating Envars in TelnetD

LD_PRELOAD forces the linker to load a library when the process is initialized

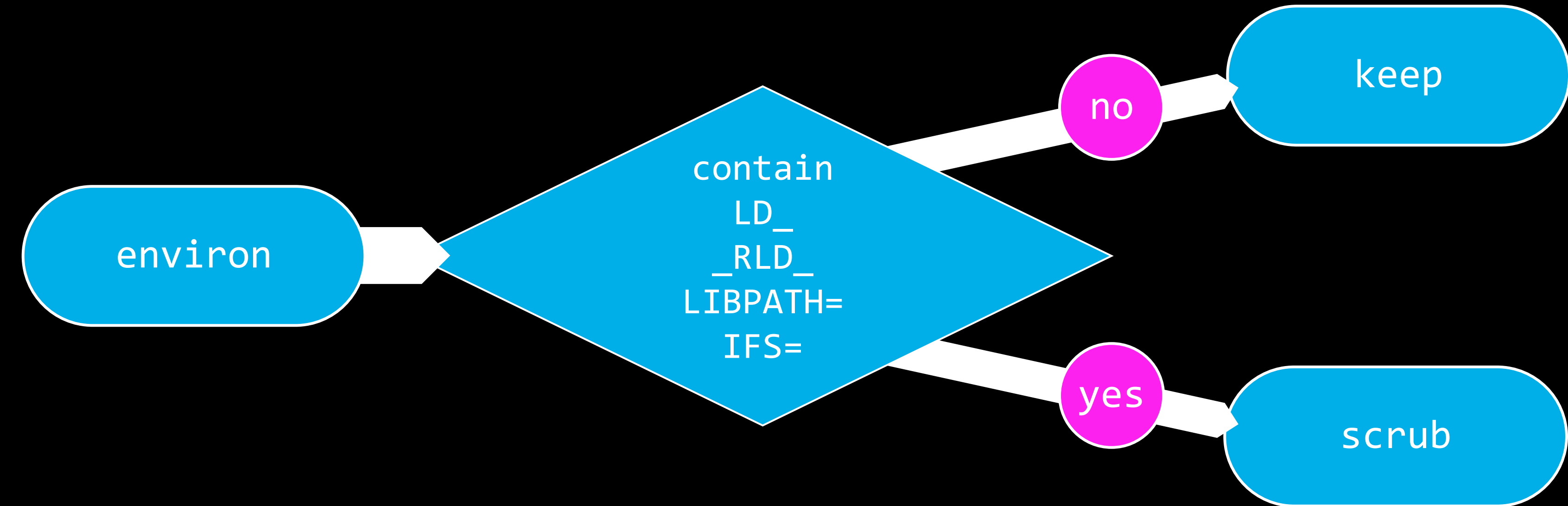
```
~$ LD_PRELOAD=/tmp/injected.so /usr/bin/login
```



Manipulating Envars in TelnetD

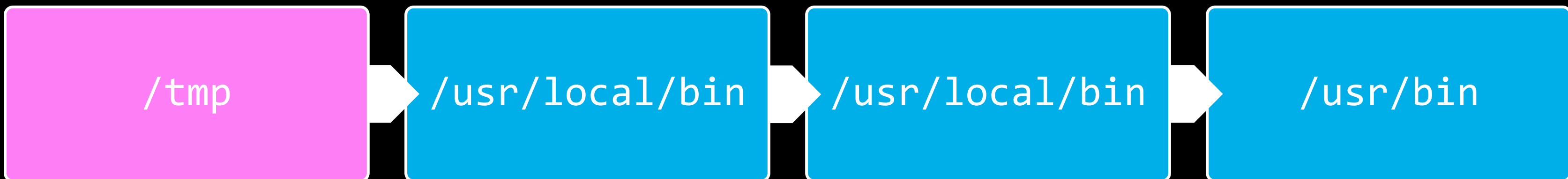
TelnetD removes malicious envvars before executing login

Security fix from 1995!



Hijack Execution Flow

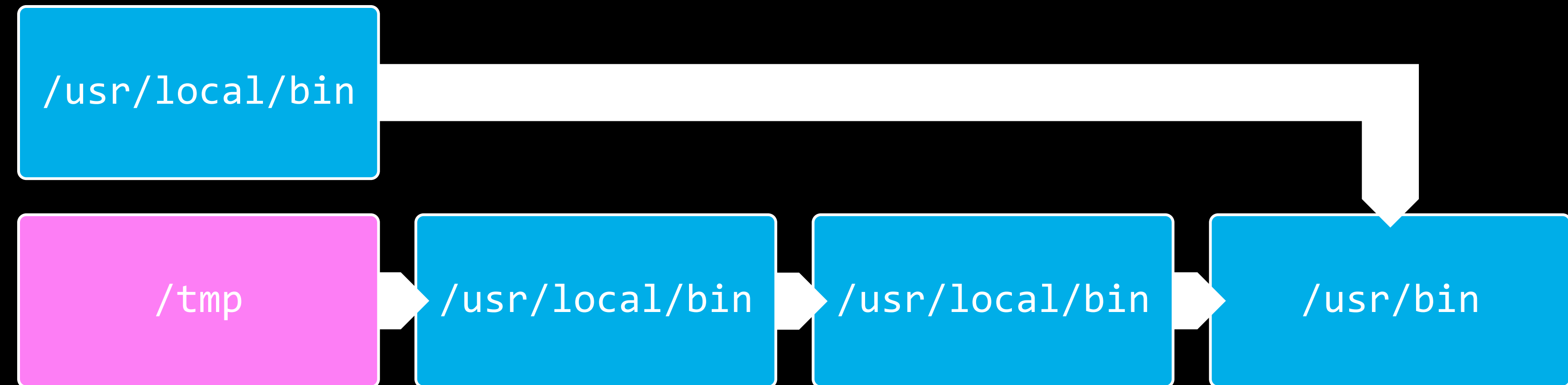
Modifying \$PATH will launch login from another directory



Hijack Execution Flow

PATH_LOGIN is compiled as a full path

No other process is launched by telnetd



Envars References

Digging through the code
might reveal unique envvars

Telnetd retrieves only \$USER

Envvars set in telnetd will be
inherited by login

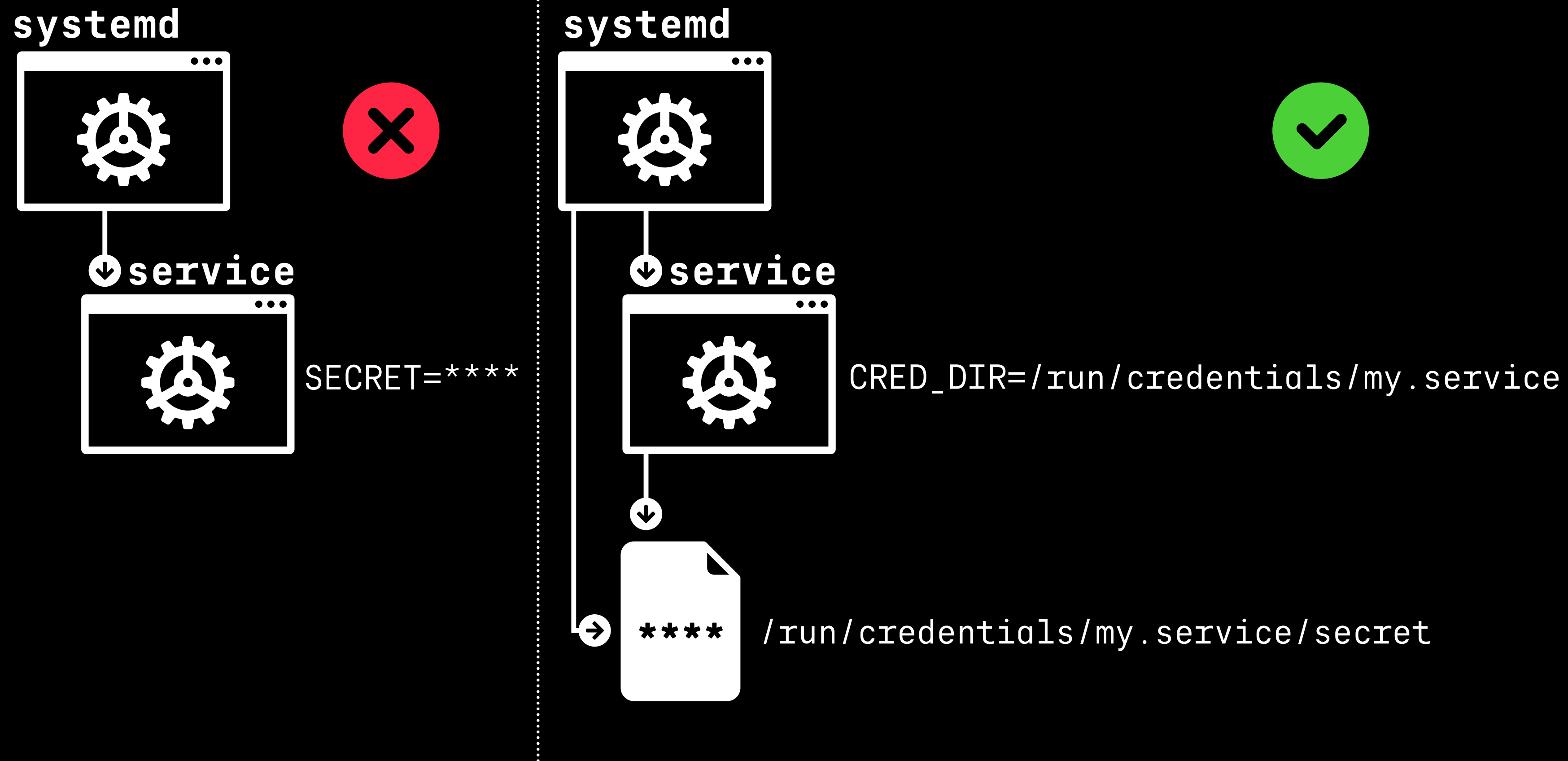


Envvars References

login references \$CREDENTIALS_DIRECTORY

Secure mechanism to supply credentials to services

\$CREDENTIALS_DIRECTORY

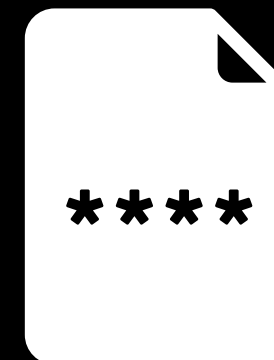
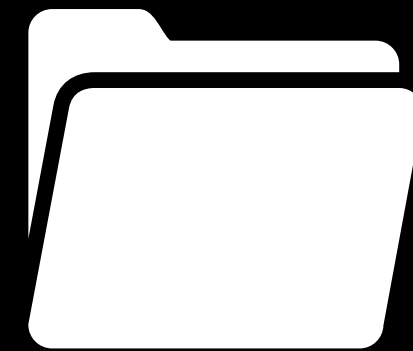


\$CREDENTIALS_DIRECTORY

unit file:

```
...  
[Service]  
ExecStart=/usr/bin/myservice.sh  
LoadCredential=secrets_file:/etc/my_creds.txt  
...
```

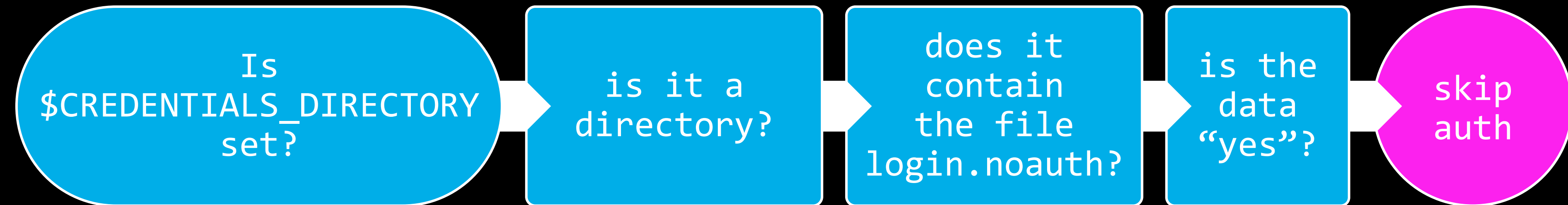
`/run/credentials/my.service`



`****-r----- root root secrets_file`

\$CREDENTIALS_DIRECTORY

login uses systemd credentials mechanism



login.noauth is even documented

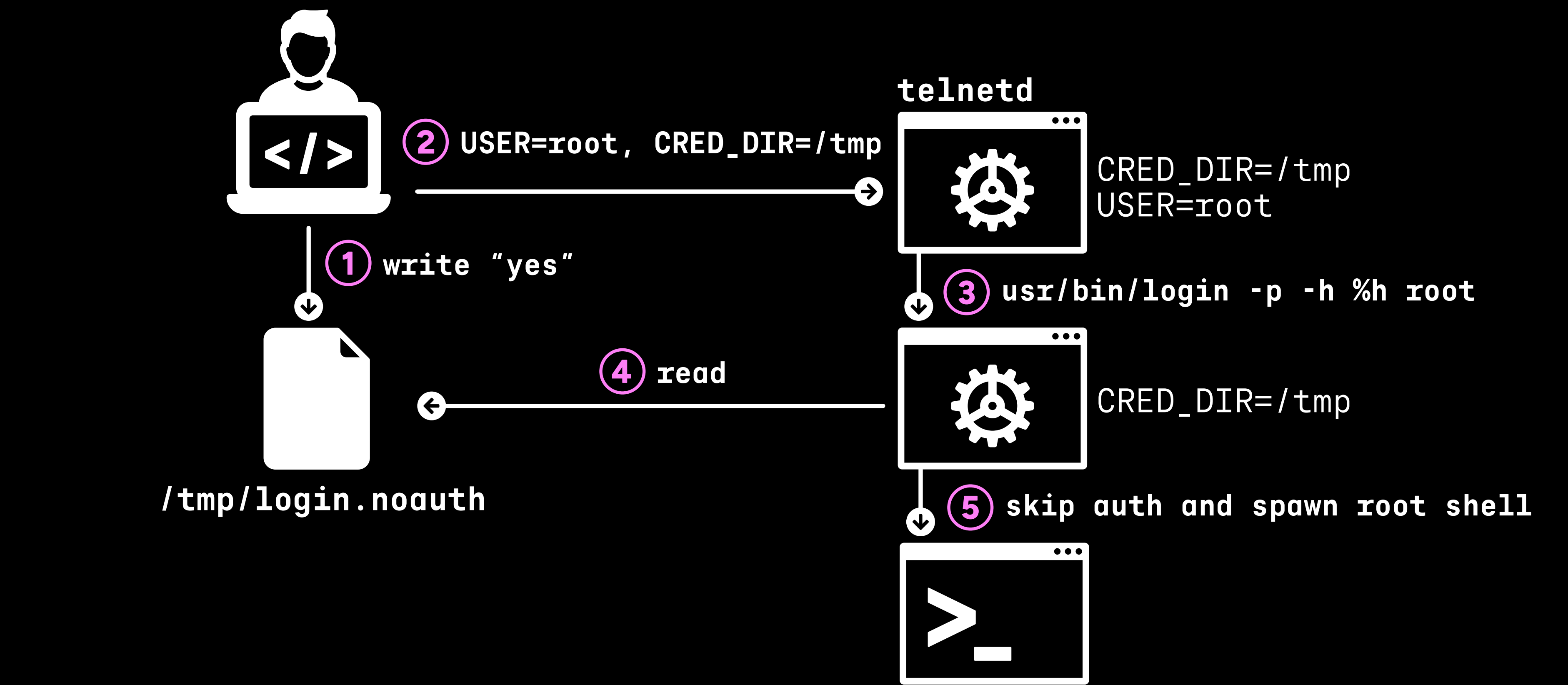
CREDENTIALS

login supports configuration via systemd credentials (see <https://systemd.io/CREDENTIALS/>).
login reads the following systemd credentials:

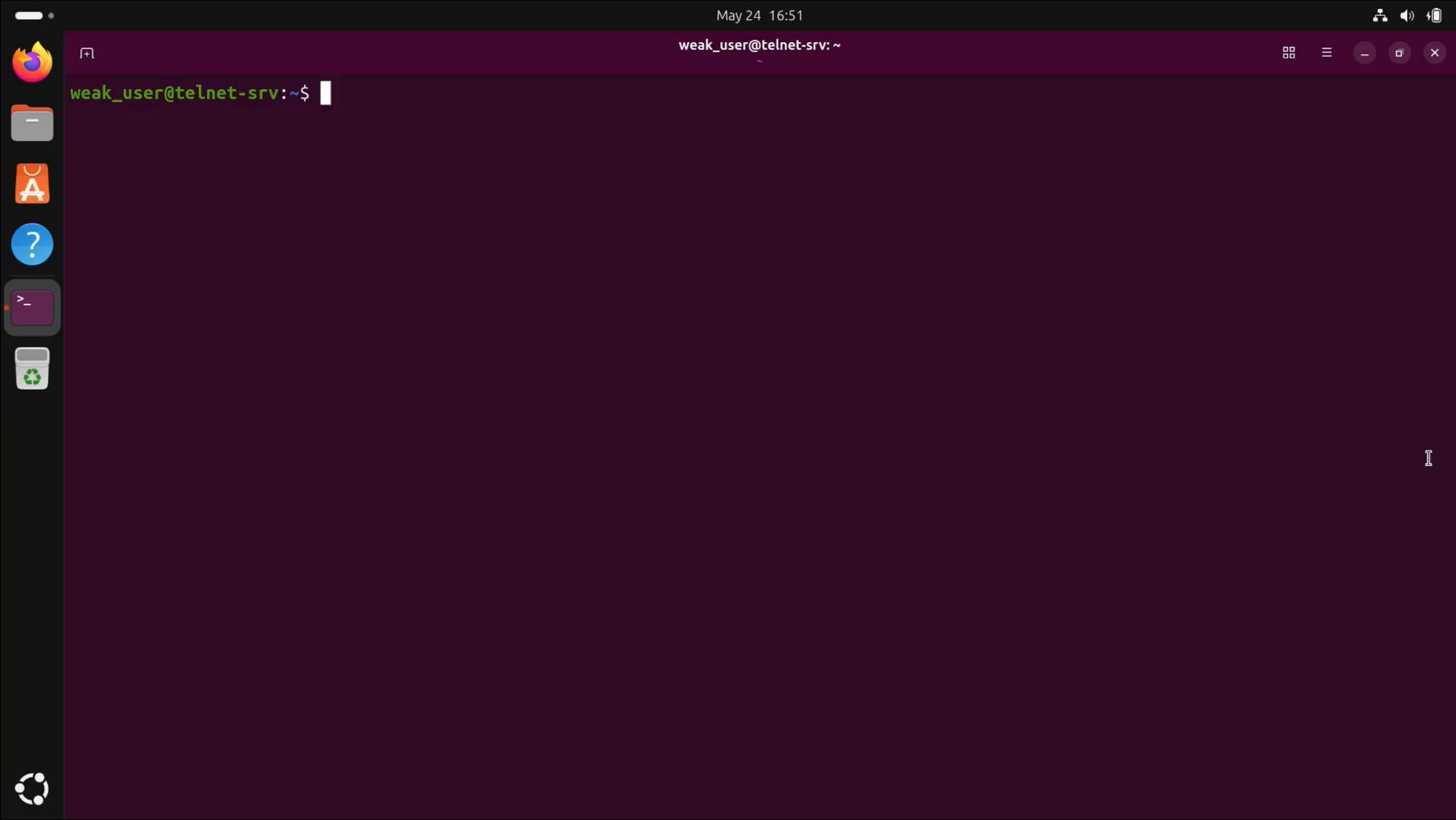
login.noauth (boolean)

If set, configures **login** to skip login authentication, similarly to the **-f** option.

Privilege Escalation in TelnetD



Demo #1



Privilege Escalation in TelnetD

Reported to GNU on February 5th, 2026

Patch was released on February 15th, 2026

\$CREDENTIALS_DIRECTORY is unset before launching login

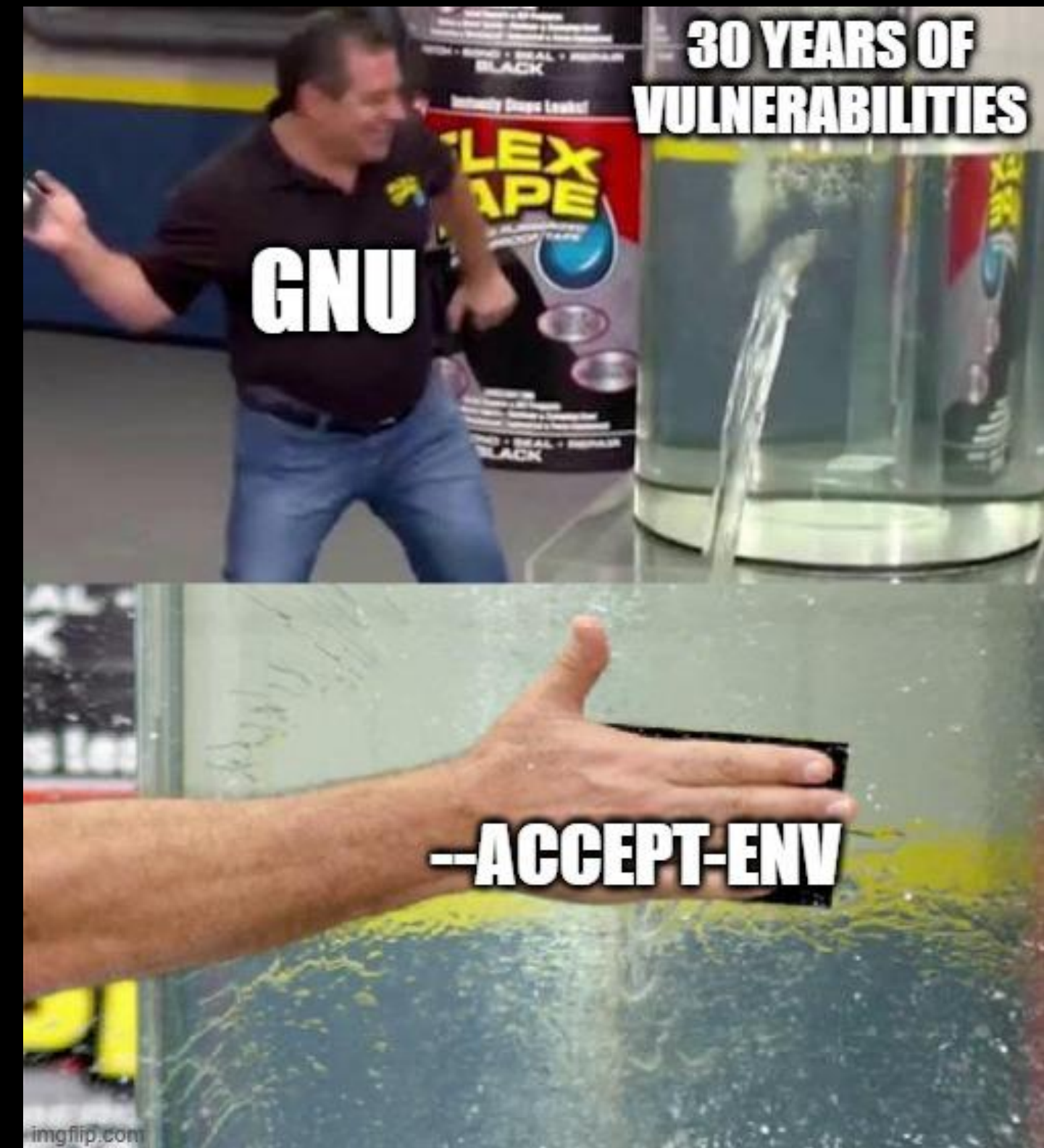
CVE-2026-28372 was issued

Disabling The Attack Surface

Another patch was released on
March 6th, 2026

telnetd no longer accepts any envvars

valid names are set using --accept-env



Expanding The Search

login.noauth was documented
and not exploited

No complex memory
corruption required

Could there be more services
with logical vulnerabilities?

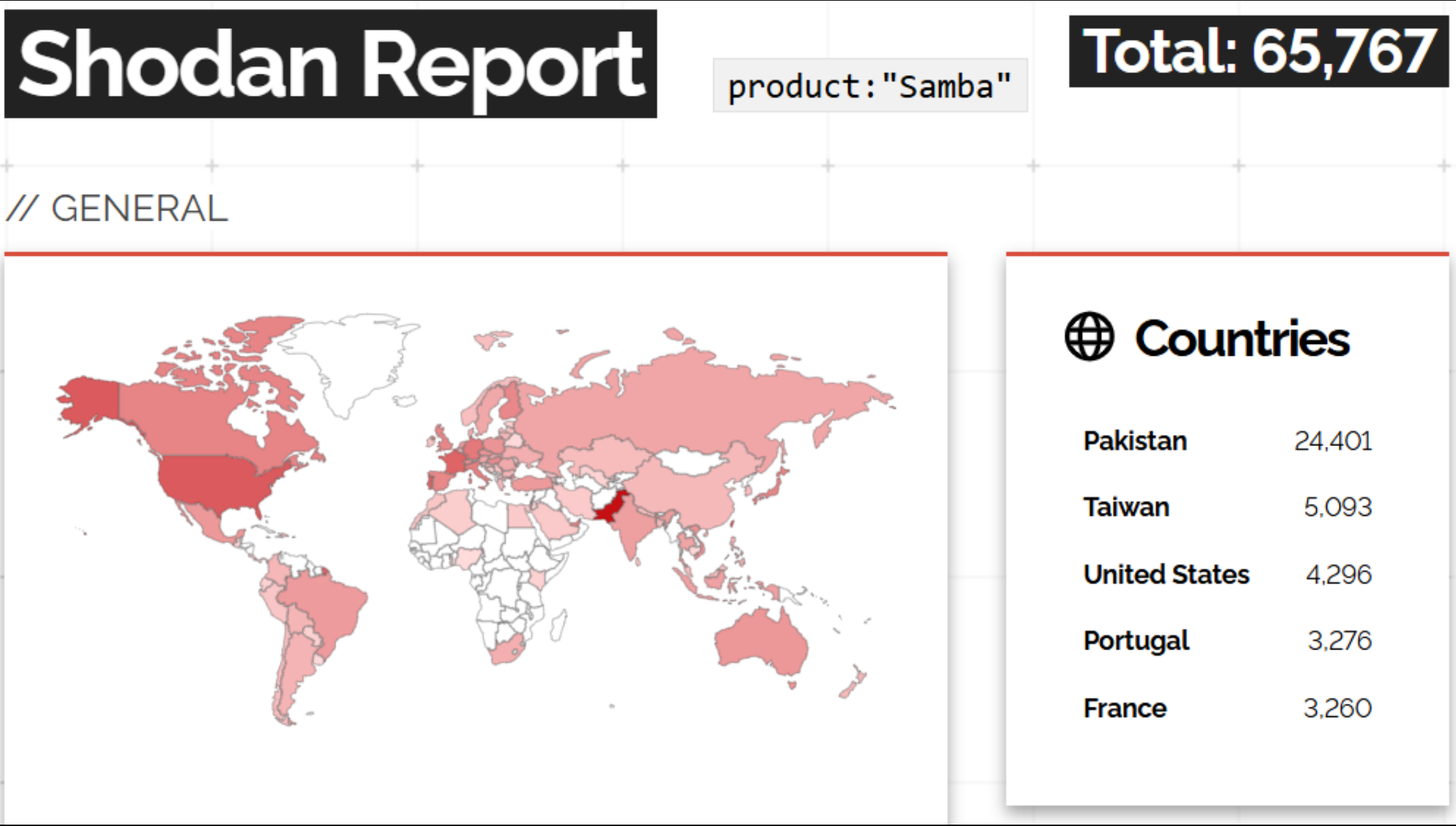


Picking The Next Target

Samba is a very common service

Installed widely

Developed over 30 years



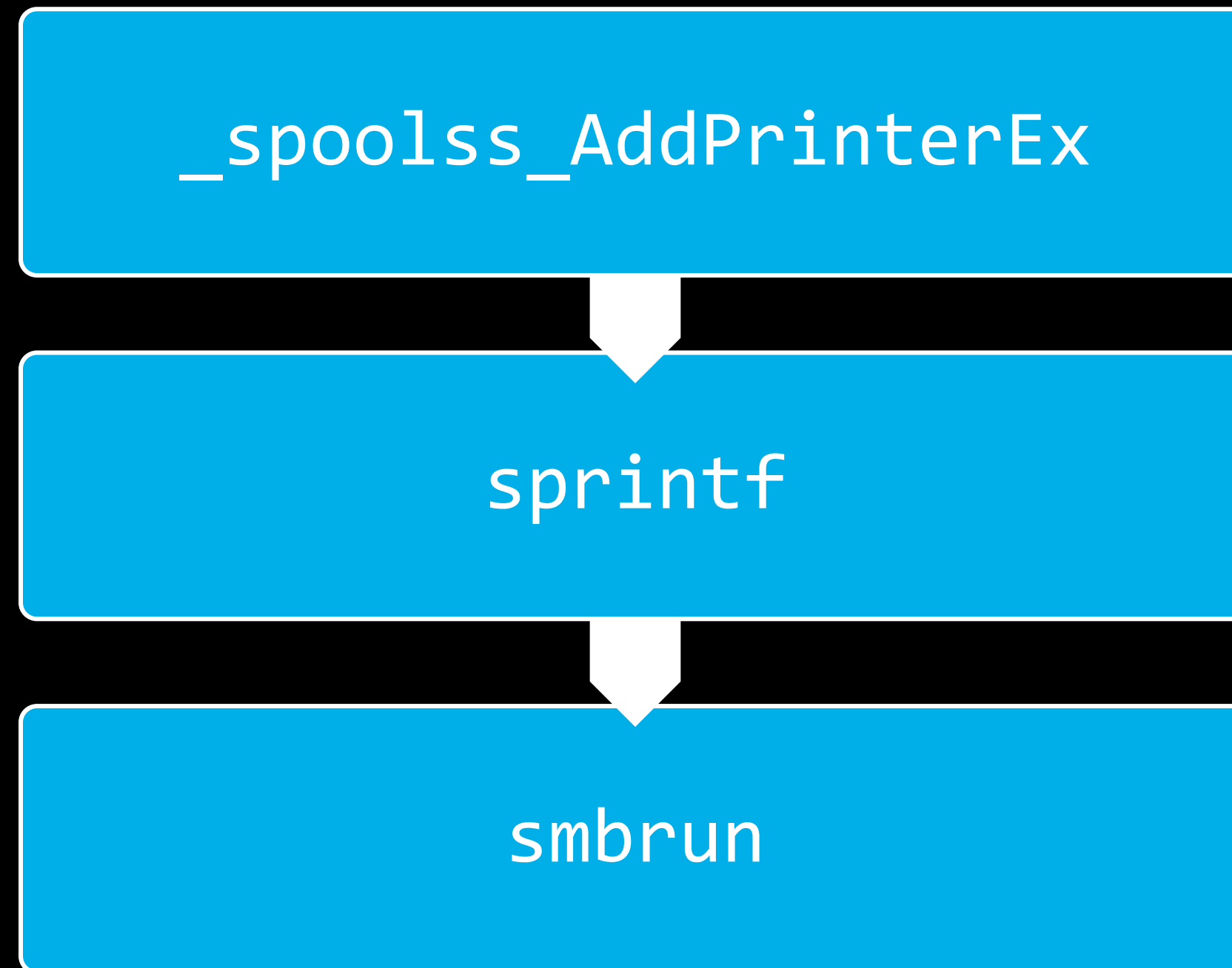
Samba Inner Workings

```
~$ cat /etc/samba/smb.conf  
add group script = /usr/sbin/groupadd %g  
add share command = /usr/local/bin/addshare  
passwd program = /bin/passwd %u  
shutdown script = /usr/local/samba/sbin/shutdown %m %t %r %f
```


Samba Inner Workings

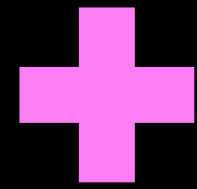
```
~$ cat /etc/samba/smb.conf  
add group script = /usr/sbin/groupadd %g  
add share command = /usr/local/bin/addshare  
passwd program = /bin/passwd %u  
shutdown script = /usr/local/samba/sbin/shutdown %m %t %r %f
```

Attempting Bash Injection

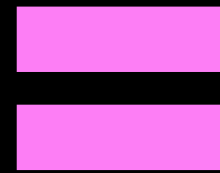


Attempting Bash Injection

```
addprinter_command "printer_name" "share_name"...
```

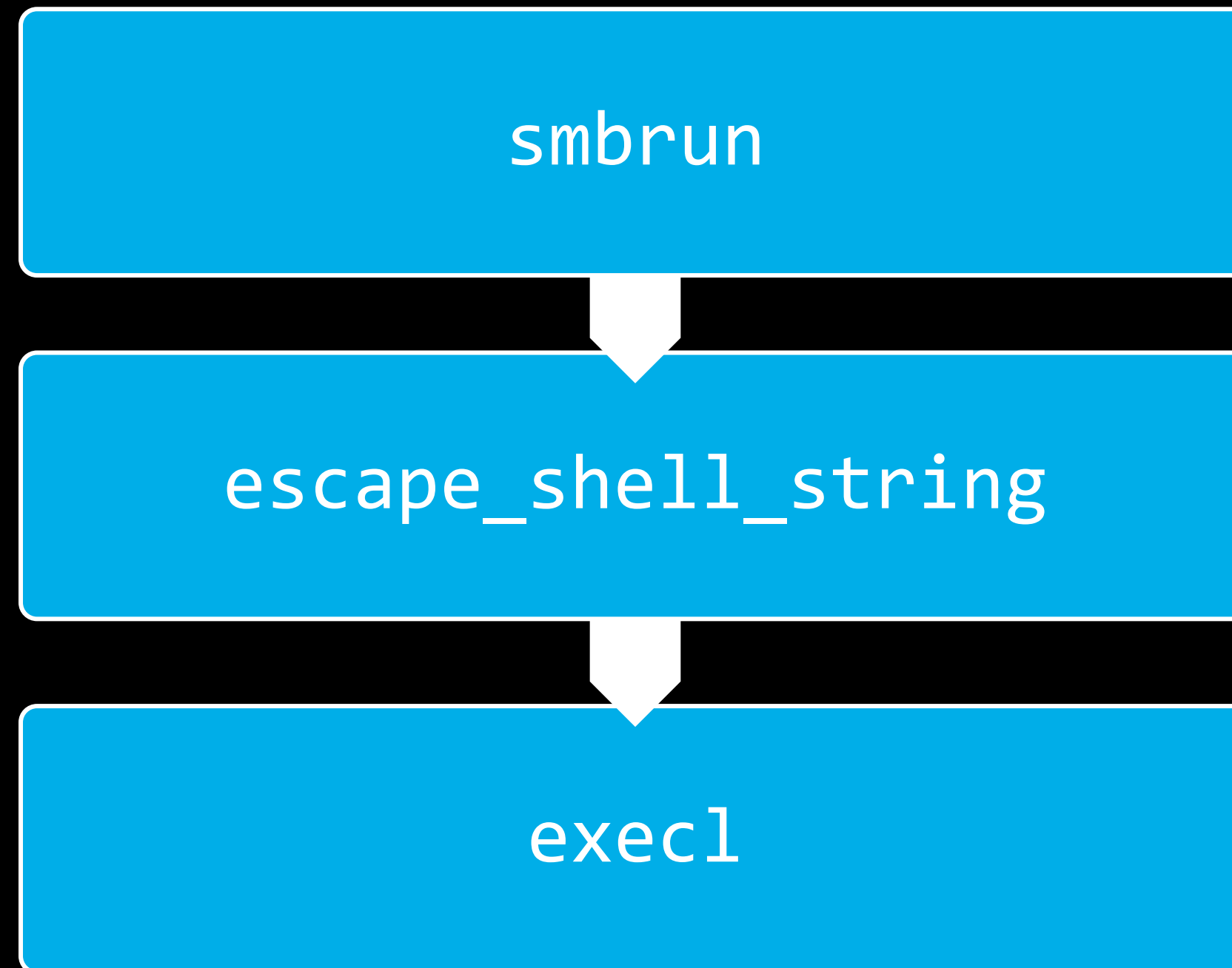


```
printer_name=a" | touch /tmp/pwned | echo "a
```



```
addprinter_command "a" | touch /tmp/pwned | echo  
"a" "share_name"...
```


Samba Sanitization Mechanism



Samba Sanitization Mechanism

Non-alphanumeric chars outside of quotes are escaped

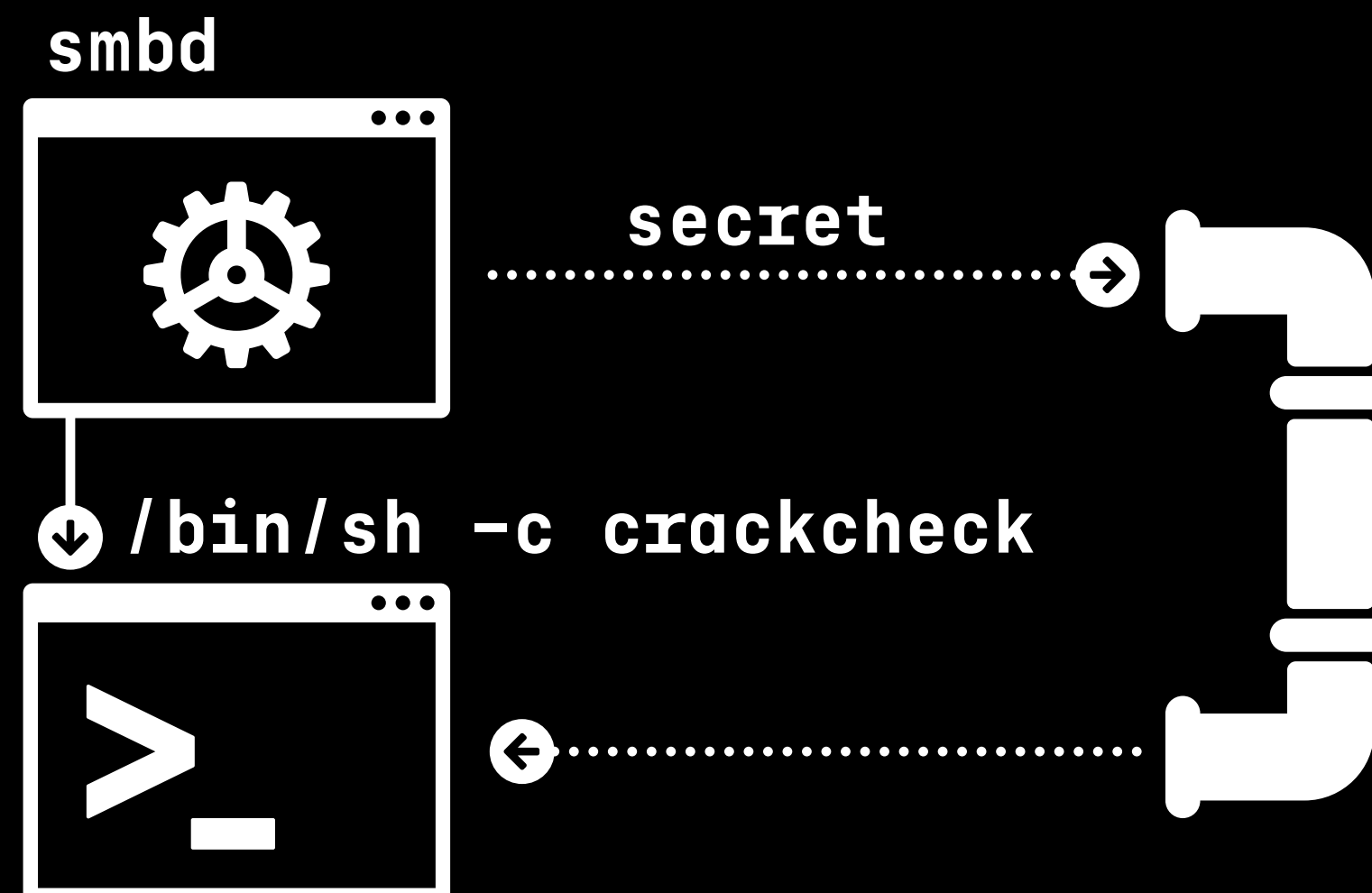
```
addprinter_command “a” \| touch /tmp/pwned \| echo  
“a” “share_name”...
```




Executes a command and sends secret over stdin

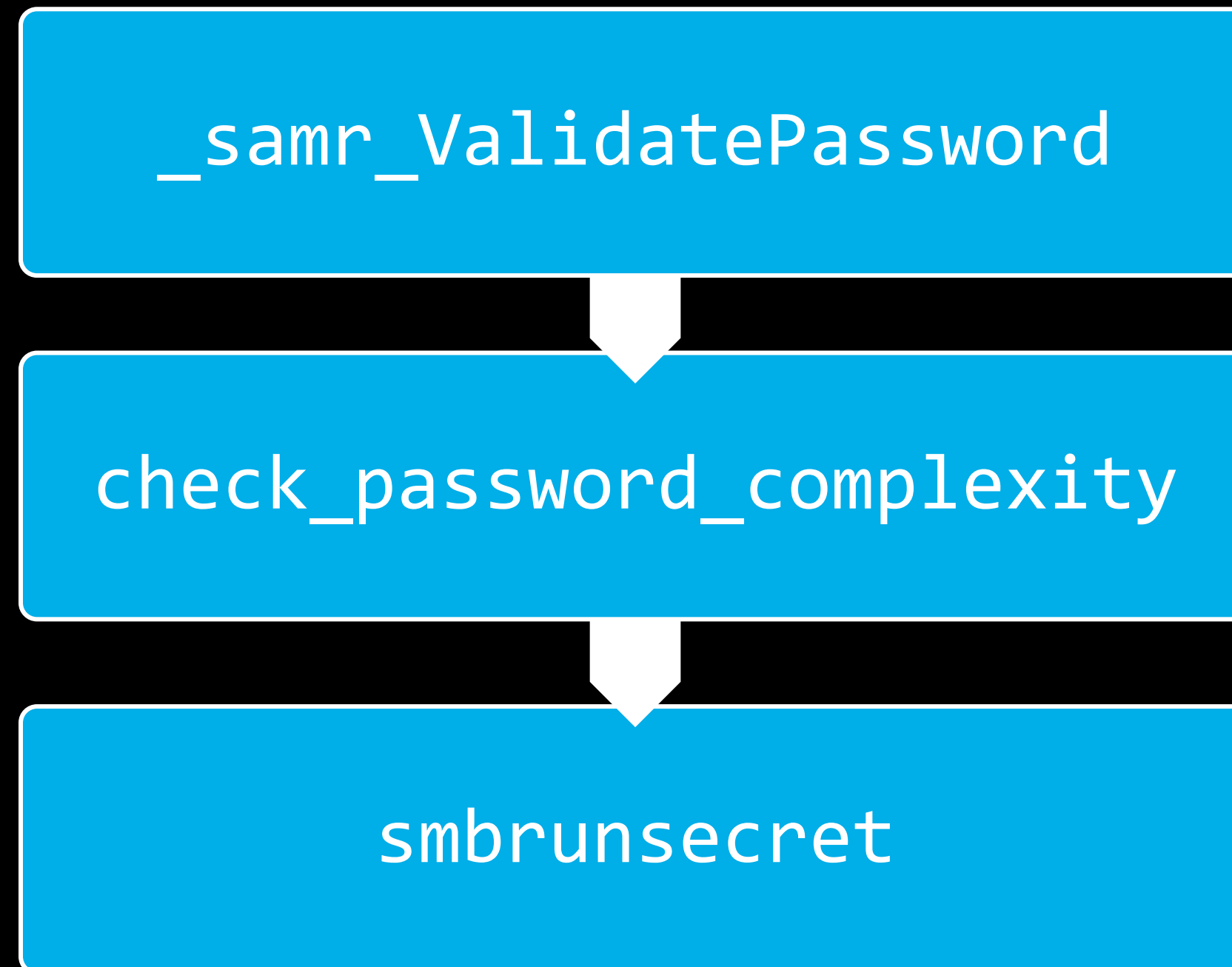
Secret isn't passed on the command line to avoid leak

escape_shell_string isn't called!





Unauthenticated RCE #1



Unauthenticated RCE #1

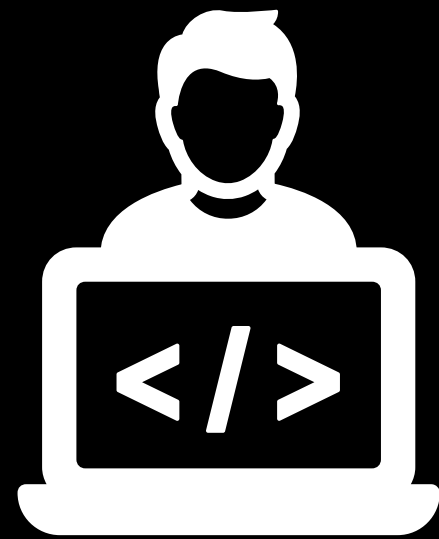
“check password script” includes %u

ncacn_ip_tcp is used

samba-dcerpcd launched independently

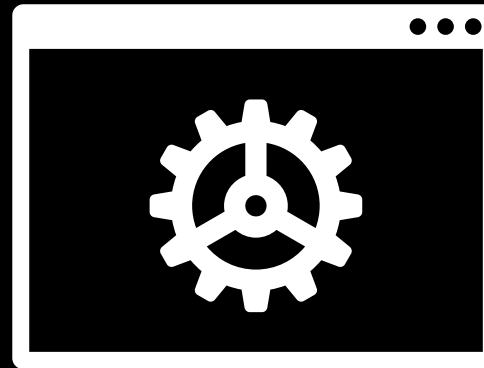
rpc start on demand helpers = no

Unauthenticated RCE #1

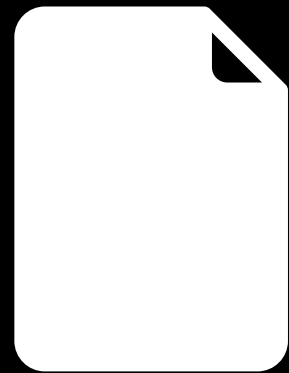


SamrValidatePassword
UserAccountName=
"I touch /tmp/pwned"

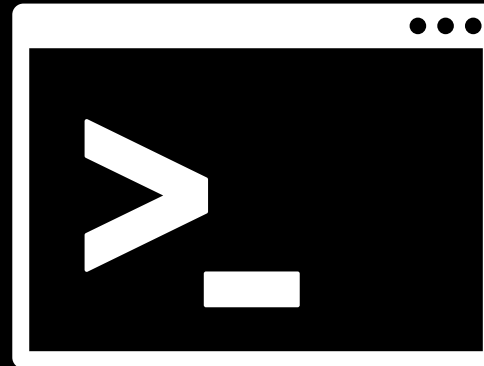
samba-dcerpcd



↓ /bin/sh -c "crackcheck I touch /tmp/pwned"



/etc/samba/smb.conf



```
[global]  
  check password script = crackcheck %u  
  rpc start on demand helpers = no
```

Demo #2

Attacker

cmd. x + v

(impacket) C:\Users\ronb>

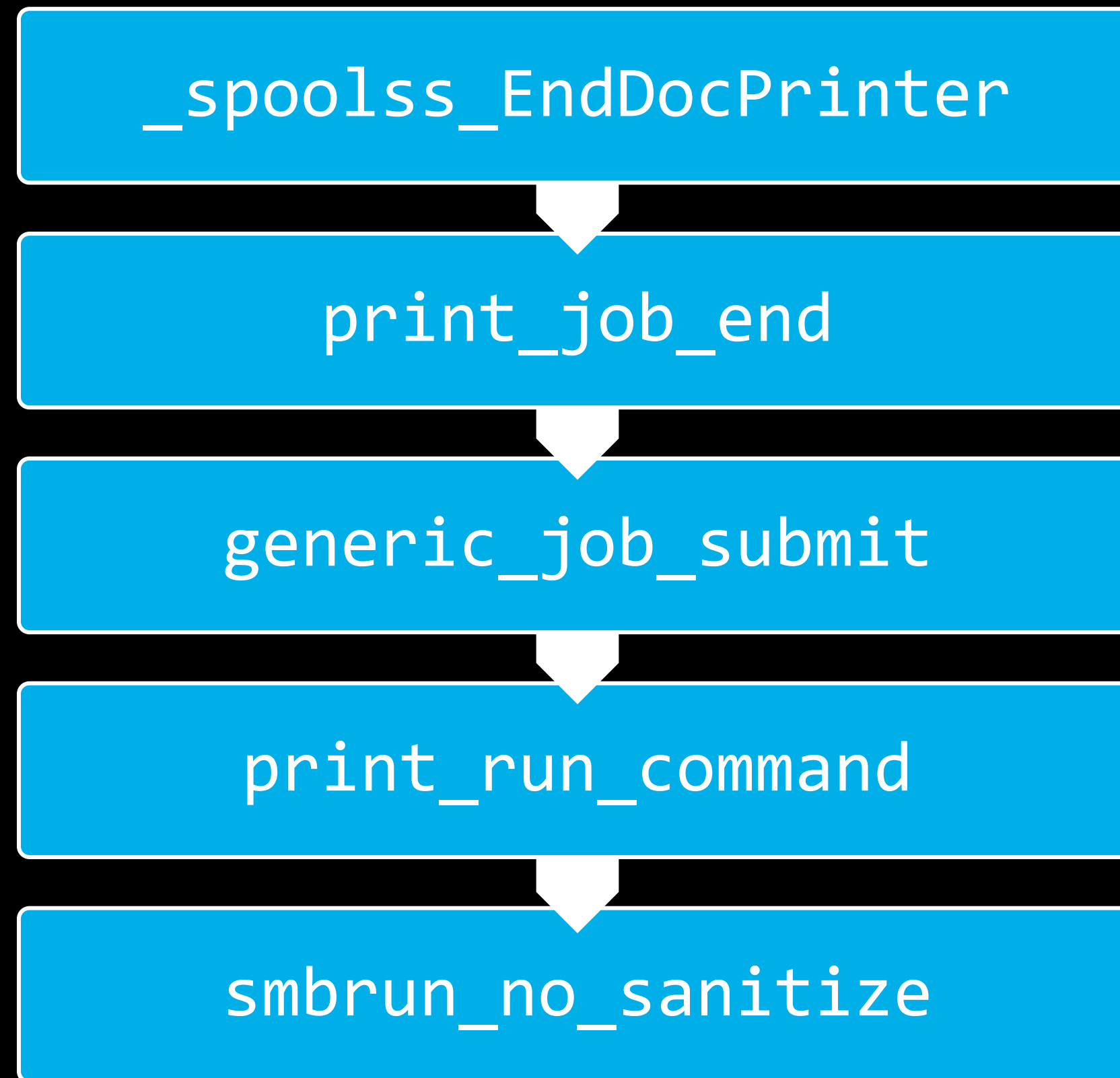
user@samba-srv: ~ x + v

user@samba-srv:~\$

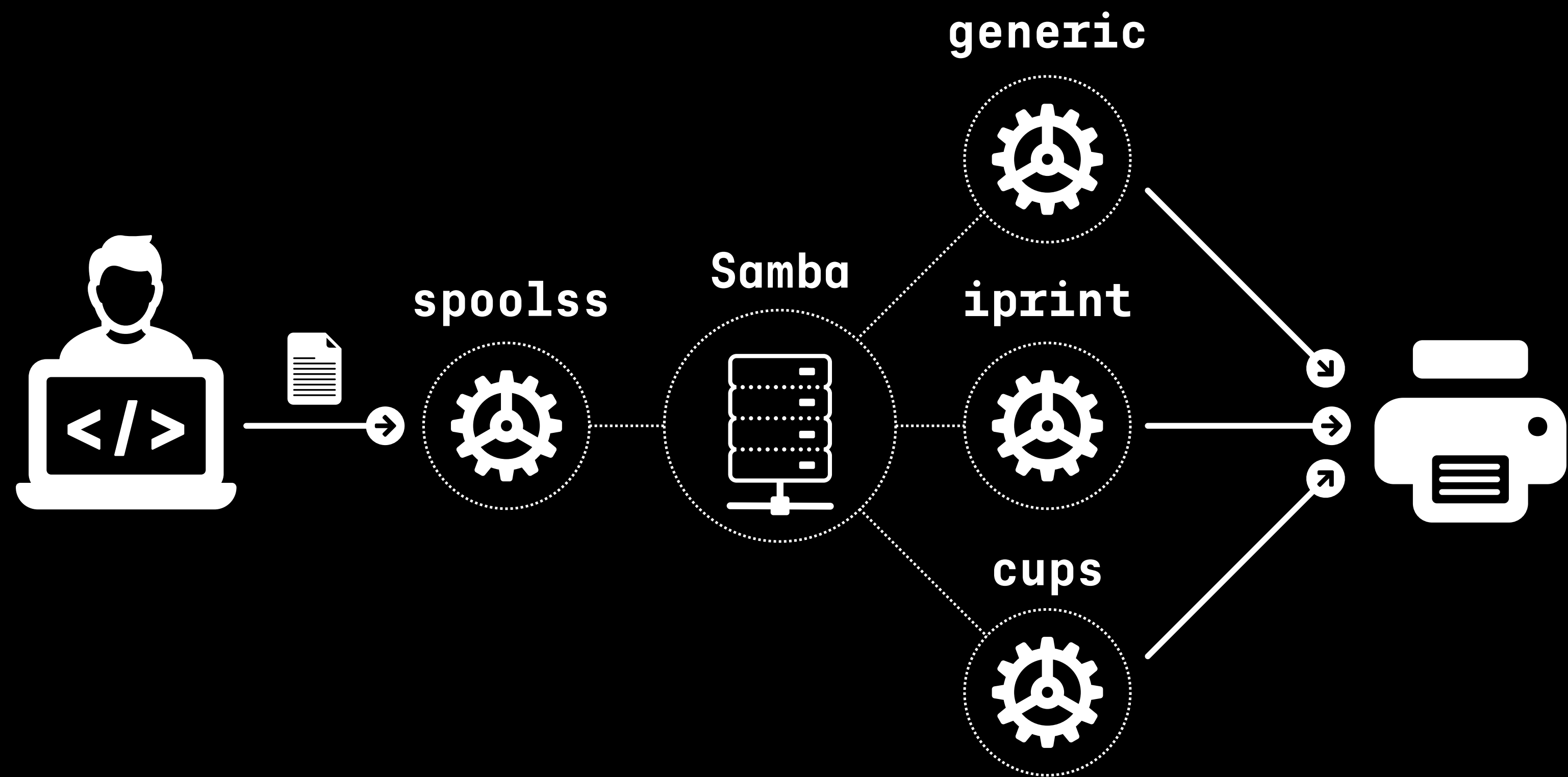
Victim



Unauthenticated RCE #2



Samba as Print Server



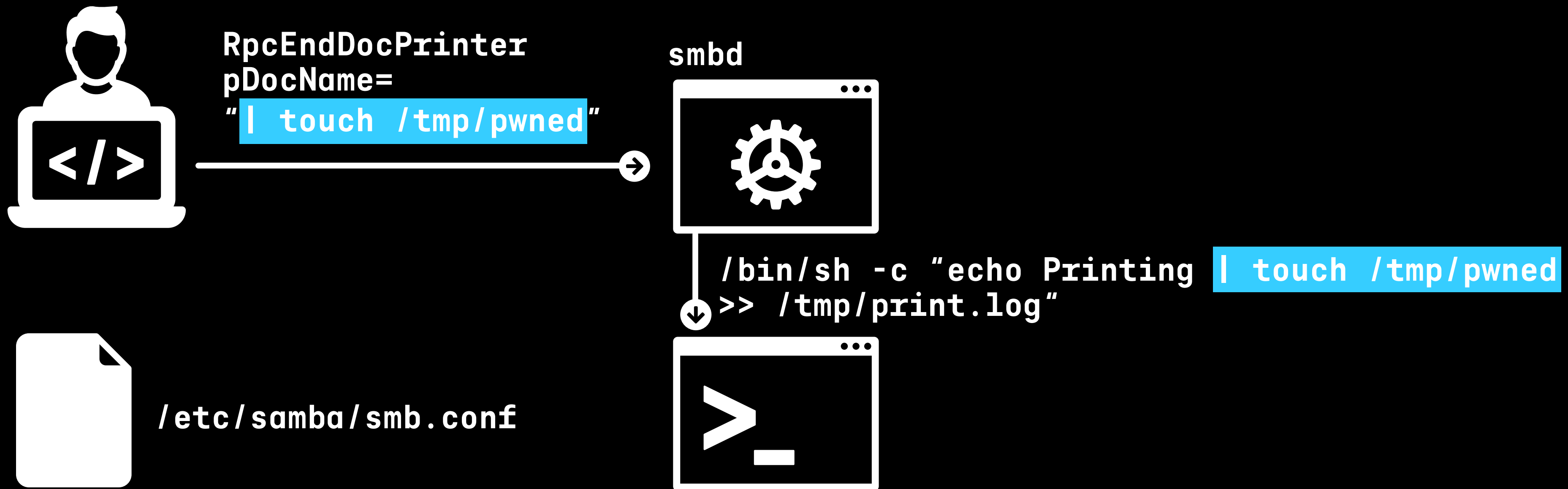
Unauthenticated RCE #2

Printer share configured

“printing” config isn’t IPRINT or CUPS

“print command” includes %J

Unauthenticated RCE #2



```
[global]
    printing = BSD
    print command = echo Printing %J >> /tmp/print.log
[Printer]
    path = /var/tmp/
    printable = yes
```




Demo #3

Attacker

(impacket) C:\Users\ronb>

user@samba-srv: ~

user@samba-srv:~\$

Victim

Disclosure

Reported to Samba on March 15th, 2026

Patch was released on May 26th, 2026

CVE-2026-4408: RCE via SAMR

CVE-2026-4480: RCE via Spoolss

Rated CVSS 10.0 by Samba

Affected all versions over 25 years!

Security Patch

Formatting engine was refactored

Admins are warned to use envvars instead of format strings

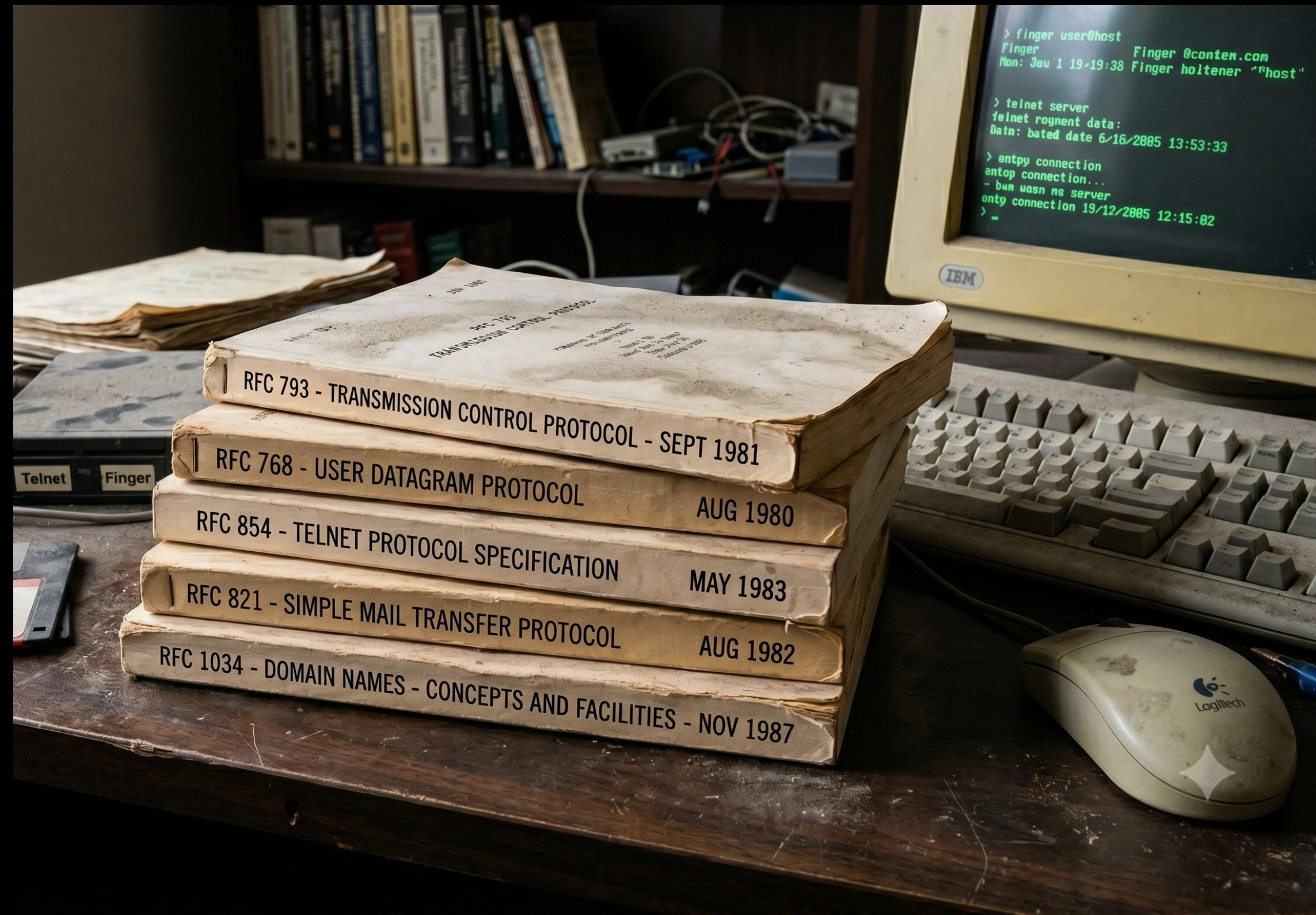
_samr_ValidatePassword is restricted to DCs

Takeaways

Issuing patches is not enough

Designs and RFCs should be updated

Legacy services don't follow modern security principles



Takeaways

The latest risks aren't necessarily the greatest

Legacy protocols are still being used in enterprise networks



Takeaways



Conclusion

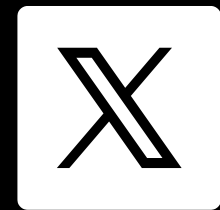
3 vulnerabilities revealed

Patch led to systemic change

Services can stay vulnerable for decades

Some network devices don't describe what's installed

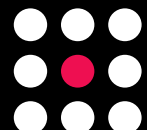
Thank you!



@RonB_Y



www.linkedin.com/in/ron-by

 SafeBreach



<https://github.com/SafeBreach-Labs/ForgottenButNotGone>